


# AUTOMATED INCIDENT TRIAGE & SOAR ARCHITECTURE

Playbook Engineering, Automation & SOC Telemetry.
Enterprise 50-Page Complete Edition.

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

# HAK CIPTA & DISCLAIMER

**Automated Incident Triage & SOAR Playbook Architecture**
Edisi Enterprise (50 Halaman Arsitektural)

Disusun oleh: Rizki Angga Pratama, S. Kom, C. Pro

Dokumen ini ditujukan secara eksklusif bagi Insinyur Deteksi (Detection Engineers), Arsitek SOC, dan Analis Respon Insiden yang berfokus pada otomasi investigasi skala raksasa menggunakan *Security Orchestration, Automation, and Response* (SOAR).

> **Peringatan Lingkungan Orkestrasi:**
> Skrip otomasi dan *Playbook API* yang dibahas di dalam buku ini memiliki kapabilitas modifikasi infrastruktur aktif (Active Response). Eksekusi skrip penahanan (Containment) yang salah di lingkungan Produksi dapat memutus jaringan peladen kritis secara permanen (Self-Inflicted Denial of Service). Uji *Playbook* secara ketat di lingkungan pra-produksi (Staging).

**Filosofi Desain:**
Buku ini diwarnai dengan tema *Titanium SOC & Cobalt Blue*. Estetika ini melambangkan efisiensi mesin analitik data yang dingin, presisi, dan dieksekusi dalam ruang operasi siber milidetik yang tak pernah tidur.

© 2026 Hak cipta dilindungi undang-undang. Panduan Otomasi Keamanan Perusahaan.

# KATA PENGANTAR

Sebuah Pusat Operasi Keamanan (SOC) modern menghasilkan lebih dari 10.000 peringatan keamanan (*Security Alerts*) setiap harinya. Jika seorang Analis L1 membutuhkan waktu rata-rata 15 menit untuk menriase satu insiden secara manual, tumpukan antrean (*Alert Fatigue*) akan menenggelamkan tim sebelum mereka bahkan sempat menemukan ancaman *Ransomware* nyata yang bersembunyi di dalam lautan data tersebut.

Era triase manual telah berakhir. Perusahaan kelas atas tidak lagi merekrut analis untuk menyalin-tempel (*Copy-Paste*) alamat IP ke VirusTotal. Mereka membangun sistem **SOAR (Security Orchestration, Automation, and Response)**. SOAR adalah otak jaringan pergelangan (*Connective Tissue*) yang mengikat SIEM, Firewall, EDR, dan Layanan Tiket menjadi satu entitas organisme otomatis.

Buku **"Automated Incident Triage & SOAR Playbook Architecture"** ini adalah kanvas rekayasa (*Engineering Canvas*) Anda. Kita akan merancang *Playbook* isolasi host tanpa celah (Zero-Downtime), mengekstrak Indikator Kompromi (IOC) menggunakan Regex canggih, dan meredam alarm palsu (*False Positives*) melalui manajemen Pengecualian (*Exception*) yang elegan. Ini adalah panduan bertahan hidup untuk mengubah kekacauan data menjadi instrumen orkestrasi siber.

*— Rizki Angga Pratama*

# DAFTAR ISI (1/2)

## BAGIAN I: FONDASI ORKESTRASI SOC


Bab 1.1 Alert Fatigue & Anatomi Kelelahan SOC ..... 7
Bab 1.2 SOAR Architecture: Integrasi SIEM & API ..... 8
Bab 1.3 Perbedaan Triage (Triase) dan Response ..... 9
Bab 1.4 Webhooks, Polling, & Event Triggers ..... 10
Bab 1.5 Standarisasi Format Data Insiden (JSON/CEF) ..... 11


## BAGIAN II: PLAYBOOK TRIASE OTOMATIS (ENRICHMENT)


Bab 2.1 Ekstraksi Entitas & IOC Parsing (Regex Lanjut) ..... 13
Bab 2.2 Threat Intelligence Integration (VirusTotal/OTX) ..... 14
Bab 2.3 Automating User Identity Context (Active Directory) ..... 15
Bab 2.4 GeoIP & ASN Baseline Triage Scoring ..... 16
Bab 2.5 Dynamic Priority Re-calculation (Risk Scoring) ..... 17


## BAGIAN III: PLAYBOOK RESPONS KINETIK (CONTAINMENT)


Bab 3.1 Network Isolation Playbooks (Zero-Downtime) ..... 19
Bab 3.2 Endpoint Containment via EDR API (CrowdStrike/Defender) ..... 20
Bab 3.3 Dynamic Firewall Blocklists & WAF Blackholing ..... 21
Bab 3.4 Active Directory Account Suspension & Revocation ..... 22
Bab 3.5 Reversible Actions (Auto-Remediation Rollback) ..... 23

# DAFTAR ISI (2/2)

## BAGIAN IV: MANAJEMEN FALSE POSITIVE & PENGECUALIAN


Bab 4.1 Logika Penekanan (Suppression) & Deduplikasi ..... 25
Bab 4.2 ASN & CIDR Whitelisting Architecture ..... 26
Bab 4.3 Behavioral Exceptions (Vulnerability Scanner Traffic) ..... 27
Bab 4.4 Granular Exclusions via Dynamic Lookup Tables ..... 28
Bab 4.5 Auto-Closing Known False Positives (No Human Touch) ..... 29


## BAGIAN V: INTEGRASI TIKET & KOMUNIKASI SECOPS


Bab 5.1 Bi-directional Jira/ServiceNow Sync ..... 31
Bab 5.2 Slack/Teams ChatOps Triage Commands ..... 32
Bab 5.3 Automated Phishing Email Analysis Pipeline ..... 33
Bab 5.4 Executive Summary Generation (Auto-Reporting) ..... 34
Bab 5.5 Audit Trails & Chain of Custody in Automation ..... 35


## BAGIAN VI & VII: AI, ML, & MASA DEPAN SOAR


Bab 6.1 - 6.5 Machine Learning Classification & LLM Triage ..... 37-41
Bab 7.1 - 7.5 Arsitektur Data Lake, OpenCTI & Custom Apps ..... 43-47


## REFERENSI & GLOSARIUM


Referensi Jurnal & Metrik SOC Lanjut ..... 48
Glosarium Terminologi SOAR ..... 49
Back Cover (The Automation Architect) ..... 50




# BAGIAN I

## Fondasi Orkestrasi SOC
## (Membangun Otak Otomasi Siber)

# BAB 1: EVOLUSI ANALITIK SIBER

## 1.1 Alert Fatigue & Anatomi Kelelahan SOC

Fenomena paling destruktif di dalam Pusat Operasi Keamanan bukanlah peretas canggih, melainkan *Alert Fatigue* (Kelelahan Peringatan). Saat sistem SIEM (Security Information and Event Management) diatur dengan ambang batas (Threshold) yang terlalu sensitif, ia memuntahkan ribuan Peringatan Palsu (*False Positives*) ke dasbor antrean analis.

Analis manusia L1 dipaksa menavigasi peringatan "Login Gagal" yang tidak berujung, perlahan-lahan menjadi kebas secara psikologis. Ketika peretas sungguhan akhirnya melancarkan serangan nyata melalui peringatan yang tenggelam di urutan ke-800, analis manusia akan mengabaikannya (Klik *Resolve* buta). Di sinilah arsitektur mesin penyaring otonom (SOAR) menjadi satu-satunya penawar kelelahan kognitif ini.

## 1.2 SOAR Architecture: Integrasi SIEM & API

SOAR bertindak sebagai lapisan eksekusi asinkron di atas SIEM. SIEM (seperti Splunk atau Elastic) bertugas sebagai mesin Analitik Statis dan Agregator Log. Saat kueri mendeteksi anomali, SIEM membungkus peringatan tersebut menjadi objek JSON dan mengirimkannya (via *Webhooks* atau REST API) ke platform SOAR (Cortex XSOAR, Splunk Phantom, atau Tines).

SOAR tidak menyimpan petabyte log; ia murni mesin Keadaan (State Machine). Setiap peringatan yang masuk dibuatkan satu "Insiden/Kasus" baru. SOAR kemudian memicu alur kerja (*Playbook*) visual (Node-based) yang melakukan *Fetch API* ke puluhan alat keamanan eksternal lainnya (EDR, LDAP, Firewall) untuk mengumpulkan konteks komprehensif tanpa analis perlu membuka 10 tab *Browser* berbeda.

## 1.3 Perbedaan Triage (Triase) dan Response

Dalam otomatisasi siber, terdapat batas doktrin yang tegas antara **Triase (Triage)** dan **Respons (Response)**.

**Triase Otomatis (Enrichment):** Adalah proses investigasi pasif. Mengambil alamat IP, memeriksanya ke *Threat Intel*, mengambil *Username* dari Active Directory, dan menghitung Skor Risiko (Risk Score). Triase 100% aman dan tidak merusak ketersediaan sistem. Ini dapat dijalankan sepenuhnya otomatis pada semua tiket tanpa intervensi manusia.

**Respons (Containment):** Adalah eksekusi modifikasi aktif. Memblokir IP di Firewall, membunuh proses (Kill Process) di EDR, atau me-*Reset Password* pengguna. Respons berisiko tinggi. Kesalahan deteksi otomatis yang memicu respons otonom dapat melumpuhkan domain perusahaan. Arsitektur yang baik sering kali menempatkan jeda "Menunggu Persetujuan Analis" (Manual Approval Node) sebelum transisi dari Triase ke Respons Kinetik.

## 1.4 Webhooks, Polling, & Event Triggers

SOAR menggunakan dua metodologi komunikasi antarmuka (Ingestion). Yang pertama adalah **Polling (Tarik)**: Platform SOAR memiliki skrip konektor yang berjalan setiap 5 menit, masuk (Log in) ke API SIEM, dan mengeksekusi kueri `get_new_alerts()`. Kekurangannya adalah keterlambatan latensi hingga 5 menit.

Yang kedua dan lebih unggul untuk Enterprise adalah **Webhooks (Dorong)**. SIEM dikonfigurasi untuk secara proaktif (Real-Time) menembakkan muatan (*Payload* HTTP POST) seketika detik peringatan terdeteksi, menabrak *URL Endpoint* penerima SOAR. Pendekatan berbasis-peristiwa (*Event-Driven*) ini memangkas waktu reaksi (*Mean Time To Detect / MTTD*) dari hitungan menit menjadi milidetik.

## 1.5 Standarisasi Format Data Insiden (JSON/CEF)

Karena sebuah insiden dapat berasal dari 20 produk keamanan vendor berbeda (Cisco, Palo Alto, Microsoft, CrowdStrike), format penamaan bidang datanya akan kacau balau (`src_ip` vs `SourceAddress` vs `ip_src`). SOAR akan lumpuh jika tidak ada Ontologi Data seragam.

Arsitek SOAR mewajibkan lapisan translasi Normalisasi. Segera setelah data masuk, SOAR Mapper menerjemahkannya ke dalam Skema Kejadian Umum (Common Event Format / CEF) atau *Elastic Common Schema* (ECS). Jadi, tidak peduli dari mana asalnya, *Playbook* Otomatis hanya perlu membaca satu bidang statis: `incident.source.ip`. Normalisasi ini memungkinkan Anda menggunakan satu *Playbook* untuk puluhan sumber log yang berbeda.




# BAGIAN II

## Playbook Triase Otomatis
## (Konversi Data Mentah Menjadi Intelijen)

# BAB 2: ENRICHMENT & PRA-ANALISIS

## 2.1 Ekstraksi Entitas & IOC Parsing (Regex)

Langkah Node (Langkah) pertama di setiap *Playbook* SOAR adalah Ekstraksi Indikator Kompromi (Indicators of Compromise / IOC). Seringkali, peringatan SIEM memuat jejak peretas di dalam kolom teks deskripsi panjang yang tidak terstruktur.

```
        # Python Node: Ekstraksi IP Address berbasis Regex Tepat import re def
extract_ips(raw_description): # Regex IP valid tanpa mencakup string konyol 999.999.x pattern =
r'\b(?:(?:25[0-5]|2[0-4][0-9]|[01]?[0-9][0-9]?)\.){3}(?:25[0-5]|2[0-4][0-9]|[01]?[0-9][0-9]?)\b'
found_ips = re.findall(pattern, raw_description) return list(set(found_ips)) # Kembalikan list
unik (Deduplikasi)
```

Skrip otomatis membaca kolom pesan deskripsi mentah, menambang setiap alamat IP, Hash MD5/SHA256, atau URL mencurigakan menggunakan *Regular Expressions (Regex)* kelas perusahaan, lalu menyimpannya dalam variabel konteks Kasus (Case Context). Ekstraksi akurat adalah fondasi karena jika Regex gagal, seluruh proses triase berikutnya akan ikut buta.

## 2.2 Threat Intelligence Integration

Setelah mendapatkan IOC, *Playbook* tidak boleh berhenti. Ia secara paralel menembakkan (Multi-Threading REST API Calls) variabel IOC tersebut ke layanan Intelijen Ancaman (Threat Intel) eksternal berbayar dan gratis, seperti VirusTotal (VT), AlienVault OTX, atau Recorded Future.

SOAR menarik laporan metrik keamanan: Berapa mesin vendor Antivirus di VT yang mencap IP tersebut berbahaya? Apa reputasi skor URL-nya? SOAR mengurai (Parse) balasan JSON dari vendor ini, lalu membungkusnya ke dalam satu Tabel Markdown yang rapi (Unified Intel Report) dan menyisipkannya langsung ke dalam antarmuka Peringatan (Alert UI). Analis kini hanya tinggal membaca satu ringkasan matang, menghemat 15 menit waktu pencarian per peringatan.

## 2.3 Automating User Identity Context (AD)

Sebuah serangan *Phishing* akan dinilai berbeda secara ekstrem tergantung pada SIAPA korbannya. Jika kredensial yang dicuri milik Staf Magang, insiden dinilai "Menengah". Jika milik Administrator Basis Data (DBA) atau CEO, insiden menjadi "Kritis".

*Playbook* Otomatis menambang *Username* korban, lalu mengeksekusi integrasi `Get-ADUser` (Active Directory/Entra ID API). SOAR menarik *Title* (Jabatan), *Department* (Departemen), status Privileged Access Management (PAM), dan nomor ponsel. Data profil kepegawaian ini memberikan Konteks (Contextual Awareness) mematikan bagi Analis untuk menentukan apakah ada risiko pergerakan lateral (Lateral Movement) berisiko tinggi.

## 2.4 GeoIP & ASN Baseline Triage Scoring

Tidak semua peringatan bervolume tinggi berbahaya. Untuk membedakan serangan *Brute-Force* dari *Scanner* internet massal tak berbahaya, SOAR melakukan resolusi Geografis (GeoIP) dan Sistem Otonom (ASN / Autonomous System Number).

Jika IP sumber berasal dari Blok ASN Pemindai Keamanan Sah (seperti Shodan.io, Censys, atau Qualys) yang sudah ada di dalam *Lookup Table* putih (Whitelist) SOC, *Playbook* akan secara otomatis menurunkan tingkat keparahan (*Severity*) Peringatan tersebut menjadi "Low" atau "Informational". Sebaliknya, jika IP tersebut diresolusi ke negara bersanksi (Embargoed Nations) atau ISP proksi anonim (Tor Nodes), Skor Insiden dikalikan ganda secara langsung.

## 2.5 Dynamic Priority Re-calculation

Produk akhir dari seluruh proses Automasi Triase/Enrichment ini bukanlah aksi kinetik, melainkan **Perhitungan Ulang Risiko Dinamis (Dynamic Risk Scoring)**.

SOAR menggabungkan: (1) Deteksi Kritis SIEM + (2) Deteksi VT Merah + (3) Korban adalah CEO + (4) Asal dari IP Tor. Skrip Python SOAR menyatukan semua koefisien ini, menimpa (Override) status peringatan asal "Medium" menjadi "CRITICAL: P1", mengirimkan notifikasi *PagerDuty* ke Tim On-Call 24/7, dan memindahkan tiket ke urutan paling atas dari seluruh antrean (Queue) analis, menjamin ancaman paling nyata ditangani dalam hitungan detik (Zero-Day prioritization).




# BAGIAN III

## Playbook Respons Kinetik
## (Eksekusi Containment Tingkat Lanjut)

# BAB 3: ORKESTRASI KARANTINA

## 3.1 Network Isolation Playbooks

Setelah Analis mengklik tombol "Approve Containment" (atau Skrip menilainya 100% aman untuk dikarantina otomatis), SOAR berpindah fase menjadi **Active Response**. Operasi paling umum adalah Isolasi Jaringan tanpa mematikan mesin (Zero-Downtime Isolation).

SOAR mengeksekusi integrasi *Switching/SDN API* (seperti Cisco ACI atau VMware NSX). Ia tidak memutus total (Shutdown) peladen. Skrip menempatkan *MAC Address* mesin yang terinfeksi ke dalam "Karantina VLAN" atau menyuntikkan kebijakan Mikro-Segmentasi yang secara brutal membunuh semua lalu lintas *Outbound* (Keluar) menuju IP C2 (Command & Control) peretas, tetapi tetap membuka Port 22 (SSH) khusus untuk IP jaringan Manajemen Tim Forensik (IR Team) agar investigasi langsung tetap bisa dilanjutkan di mesin hidup.

## 3.2 Endpoint Containment via EDR API

Respons jaringan sering kali lambat jika staf bekerja jarak jauh dari jaringan Wi-Fi rumah mereka. Solusi modern menggunakan **EDR (Endpoint Detection and Response) Containment**.

Melalui antarmuka API CrowdStrike Falcon atau Microsoft Defender for Endpoint, SOAR mengirimkan instruksi `Network Contain`. Agen EDR di laptop karyawan (baik di kantor maupun di kedai kopi luar negeri) langsung menjatuhkan dinding api lokal berbasis kernel. Laptop kehilangan kemampuan berselancar internet lokal secara instan, mengunci proses *Ransomware* agar tidak menyebar ke komputer karyawan lain, sementara terowongan awan EDR tetap dipertahankan murni bagi Analis IR (Live Response Terminal).

## 3.3 Dynamic Firewall Blocklists & WAF Blackholing

Bagi Serangan Penolakan Layanan Bervolume Tinggi (L7 DDoS/Web Floods) atau injeksi SQL massal, EDR tidak relevan (karena serangan menabrak *Edge* Publik). *Playbook* merespons dengan **Dynamic Edge Blackholing**.

SOAR menarik puluhan alamat IP pemindai agresif dari *Alert*, memformatnya menjadi *Tag/Dynamic Address Group*, lalu mendorong (Push API) IP-IP tersebut ke dalam *External Dynamic List (EDL)* Palo Alto Networks atau *Cloudflare WAF IP Blocklist*. Dalam interval 60 detik, perimeter gerbang luar perusahaan menyesuaikan diri dan mematikan koneksi *Threat Actors* tersebut secara global di seluruh cabang kantor (Global Synchronized Defense) sebelum mereka bisa beralih target.

## 3.4 Active Directory Account Revocation

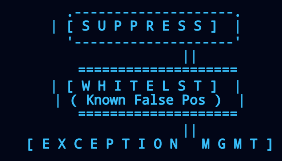
Ketika insiden terdeteksi sebagai "Identitas yang Dikompromikan" (*Compromised Credentials / Impossible Travel Alert*), mengunci perangkat keras tidak cukup karena peretas menggunakan otentikasi awan (Cloud Login).

*Playbook* Otomatis mengambil peran Administrasi IAM (Identity Access Management). Skrip PowerShell Otomatis SOAR mengirimkan tiga instruksi serentak ke Azure AD / Okta: (1) `Revoke-AzureADUserAllRefreshToken` (Menghancurkan Token akses JWT hidup di semua peramban peretas), (2) `Disable-ADAccount` (Mengunci formulir *Login* baru), dan (3) Mereset kata sandi secara acak (Force Password Reset). Serangan pengambilalihan akun terpotong secara kejam dalam 2 detik, membuang peretas keluar dari sesi Microsoft 365 mereka seketika.

## 3.5 Reversible Actions (Auto-Remediation Rollback)

Dosa terbesar otomasi adalah penahanan permanen (Permanent Lockdown) yang terlupakan. Jika Analis mengkarantina alamat IP, namun lupa membukanya kembali seminggu kemudian, *Firewall* perlahan dipenuhi sampah IP dan dapat memblokir mitra bisnis sah secara tak sengaja (IP Re-assignment).

Setiap *Playbook Containment* Enterprise wajib memiliki **Un-containment Loop (Rollback)**. Skrip SOAR menyimpan jejak audit setiap aksi ke dalam basis datanya, dilengkapi pengaturan Timer (Misalnya: TTL 24 Jam untuk IP Blokir Otomatis). Saat waktu usai, atau insiden Jira diklik menjadi "Ditutup - *False Positive*", SOAR secara asinkron menjalankan skrip pembalikan otomatis (Remove IP from Blocklist), mengembalikan infrastruktur TI ke postur kebersihannya semula tanpa jejak manusia (Self-Cleaning Architecture).




# BAGIAN IV

## Manajemen False Positive & Pengecualian (Merajut Kebeningan Data SOC)

# BAB 4: PENGENDALIAN KEBISINGAN (NOISE CONTROL)

## 4.1 Logika Penekanan (Suppression) & Deduplikasi

Mesin keamanan terkadang mengamuk (Event Storms). Jika konfigurasi keliru di satu peladen *Backend* membangkitkan 5,000 peringatan *Splunk* yang sama persis dalam 10 detik, SOAR tidak boleh membuat 5,000 tiket Jira atau ia akan meruntuhkan (DDoS) *Helpdesk* perusahaannya sendiri.

Node (Langkah) pra-pemrosesan pertama di SOAR adalah **Deduplikasi Lanjutan (Smart Suppression)**. Mesin mengambil *Hash ID* dari peringatan masuk (Kombinasi `Tipe Serangan + IP Sumber + IP Tujuan`). Jika Hash ID tersebut sudah ada dalam Insiden Aktif yang sedang terbuka di antrean Analis dalam 24 jam terakhir, SOAR membuang pembuatan Kasus baru. Ia hanya menempelkan hitungan (`Incident_Count += 1`) ke tiket lama tersebut (Context Merging), menyaring 5,000 badai menjadi 1 Tiket Konsolidasi rapi.

## 4.2 ASN & CIDR Whitelisting Architecture

Untuk menghilangkan *False Positive* dari peladen yang sah (seperti IP *Gateway* mitra B2B atau *Cloudflare Proxies*), analis membutuhkan arsitektur *Global Whitelisting*. Menulis filter (Exclude IP) satu per satu ke dalam Kueri Splunk itu primitif dan sangat memberatkan komputasi (CPU/Query bloat).

SOAR dan SIEM harus menggunakan **Lookup Tables Bervolume Tinggi** (misal: Redis Cache / Splunk KV Store). Daftar ini berisi rute Subnet CIDR (Misal `198.51.100.0/24`) atau Tag ASN sah. Setiap kueri deteksi SIEM hanya perlu memanggil makro `| lookup Threat_Whitelist` secara elegan. Ketika analis SOC ingin mengecualikan IP, mereka tidak memodifikasi Kueri SIEM sama sekali, melainkan menambahkan IP tersebut ke Pangkalan Data Tabel (Lookup Table) dari dasbor *SOAR*, mendistribusikan kebijakan pemutihan (Whitelisting) serentak dalam milidetik.

## 4.3 Behavioral Exceptions (Vulnerability Scanners)

Pengecualian berdasarkan IP (Statis) sering gagal karena alamat *IP Cloud* dinamis. Contoh tersulit adalah menangani lalu lintas alat Pemindai Kerentanan internal (seperti Tenable Nessus atau Qualys) yang memang dirancang untuk "Menyerang" seluruh subnet untuk mencari kelemahan (Vulnerability Scan).

*Playbook SOAR* membangun **Behavioral Exceptions (Pengecualian Dinamis Berbasis Perilaku)**. Skrip SOAR membaca Jadwal Pemindaian (*Scan Schedule API*) dari *Qualys Security Center*. Jika *Alert Port-Scanning* EDR meledak pada pukul 02:00 AM, SOAR akan memeriksa (Check) apakah *IP Source* tersebut sedang memiliki Jadwal Pemindaian resmi dari Mesin Qualys. Jika (True/Cocok secara temporal), alarm tersebut dibatalkan (Suppressed). Jika diluar jadwal resmi, alarm dilanjutkan. Ini adalah pengecualian yang cerdas dan hidup (*State-Aware*).

## 4.4 Granular Exclusions via Dynamic Lookup

Pengecualian menyeluruh (Global Whitelisting) terlalu berbahaya. Jika Anda mendaftarkan (Whitelist) IP Peladen *Backup* secara universal, peretas yang menyusup ke peladen *Backup* tersebut kini memiliki tiket bebas untuk meretas area mana saja (Blind Spot Eksploitasi).

Manajemen Pengecualian Modern adalah **Granular Exclusions (Pengecualian Terperinci)**. Tabel pencarian tidak hanya berisi "IP A Aman". Ia berisi struktur kompleks: `IP A` aman HANYA JIKA memicu Aturan Peringatan `[Deteksi_Traffic_Besar]` menuju `IP B` pada `Port 443`. Jika peladen *Backup* yang sama mencoba mengeksekusi `PowerShell.exe` anomali, sistem TIDAK mengecualikannya. Ini menjaga tingkat akurasi filter yang mematikan *False Positives* tanpa mengorbankan (Blindfold) parameter keamanan esensial.

## 4.5 Auto-Closing Known False Positives

Tahap puncak dari manajemen Pengecualian SOAR adalah **Zero-Touch Auto-Closure (Penutupan Otonom Tanpa Sentuhan Manusia)**.

Setelah *Playbook* Otomatis menelusuri data dan menemukan bahwa peringatan "Injeksi SQL" ternyata hanyalah Skrip QA internal dari tim Pengembang (DevOps) yang sedang melakukan uji beban (Load Testing) resmi di lingkungan Staging, *Playbook* akan menghentikan eksekusi, mengisi kolom Resolusi Catatan Kasus dengan "Auto-Closed: Scheduled QA Testing by DevOps Team", lalu Menutup (Close) tiket insiden tersebut.

Analis manusia L1/L2 bahkan tidak akan pernah melihat peringatan (Alert) tersebut muncul di Dasbor Triage mereka. Beban psikologis Analis merosot hingga 60%, memungkinkan mereka fokus pada perburuan ancaman (Threat Hunting) nyata daripada berurusan dengan rutinitas teknis yang membosankan.




# BAGIAN V

## Integrasi Tiket & Komunikasi SecOps (Kolaborasi Taktis Jarak Jauh)

# BAB 5: ORKESTRASI KOLABORASI TIM

## 5.1 Bi-directional Jira/ServiceNow Sync

Pusat Operasi Keamanan tidak bekerja dalam gelembung terisolasi (Silo). Saat isolasi Jaringan diwajibkan untuk sebuah peladen produksi aplikasi krusial, tim SOC harus berkoordinasi dengan Tim Infrastruktur IT (IT Ops) yang menggunakan **Jira atau ServiceNow**.

SOAR mengeksekusi integrasi Sinkronisasi Dua Arah (*Bi-directional Sync*). Ketika Insiden terbuka di *SOAR Cortex*, sebuah Tiket *ServiceNow* terbuat secara otomatis untuk Tim IT. Jika analis SOAR menambahkan komentar (Notes) ancaman, komentar itu muncul di *ServiceNow*. Sebaliknya, jika teknisi IT menekan tombol "Aset Selesai Di-Patch" di *ServiceNow*, tiket *SOAR Cortex* ikut diperbarui (Update) atau ditutup secara ajaib tanpa komunikasi Email (*No Email Pings*), menautkan dua budaya tim melalui otomasi *API* tanpa sekat (*Frictionless*).

## 5.2 Slack/Teams ChatOps Triage Commands

Kecepatan eskalasi siber tidak kompatibel dengan lambatnya format UI Tiket Situs Web. Revolusi kolaborasi respons saat ini adalah **ChatOps (Slack / Microsoft Teams Integration)**.

Ketika alarm Kritis terpicu (Prioritas P1: *Ransomware*), Bot SOAR melompat masuk ke Kanal Slack khusus `#soc-incidents`. Bot langsung mengunggah rangkuman (Summary) laporan intelijen ke dalam ruang *Chat*. Lebih gila lagi, Komando Interaktif berjalan dua arah. Analis dapat mengetik `@SOARBot isolate host 10.0.5.2` langsung dari antarmuka kotak pesan *Slack* di *Smartphone* mereka saat sedang mengantre kopi. Bot SOAR menangkap pesan *Slack* ini (Slash Commands), dan mengeksekusi Isolasi EDR peladen tanpa Analis perlu membuka laptop mereka, memangkas menit-menit paling berharga dalam penahanan serangan.

## 5.3 Automated Phishing Email Analysis Pipeline

Serangan yang menghabiskan 80% waktu Triase Harian SOC adalah Peringatan Email Penipuan (*Reported Phishing Emails*) dari karyawan. *Playbook SOAR* Phishing ini adalah cetak biru mutlak (Masterpiece) dari efisiensi siber.

Alur Pipa (Pipeline) Otomatis: (1) Kotak Masuk *Exchange/Gmail API* menelan Email Phishing masuk. (2) SOAR membongkar (Parse) Lampiran `.EML`, menarik Teks Surat, mengekstrak URL (Regex URI), dan menjatuhkan Fail Lampiran `.docx` berbahaya. (3) Fail dieksekusi di dalam Kotak Pasir Awan Dinamis (Cuckoo Sandbox / Joe Sandbox). (4) Jika Kotak Pasir melapor *Malicious*, SOAR mengeksekusi "Search and Purge" (Hapus Paksa API) untuk menarik (Delete) email kampanye palsu tersebut dari *Inbox* 5.000 karyawan lain yang belum membacanya secara diam-diam. Seluruh proses mematikan ekosistem infeksi *Malware* ini berjalan tanpa campur tangan manusia sama sekali.

## 5.4 Executive Summary Generation (Auto-Reporting)

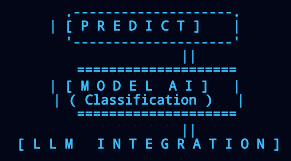
Menerjemahkan kerumitan triase siber (Log Hexadecimal, IOC, YARA Signatures) menjadi bahasa laporan insiden eksekutif yang dapat dimengerti oleh Direktur Bisnis (CISO / Board of Directors) sangat menyiksa Analis Teknis.

Platform SOAR memanfaatkan **Templating Engine (Jinja2) atau Generative AI (LLM)** untuk otomatisasi pelaporan. Begitu sebuah Kasus Kritis ditutup, skrip mengumpulkan seluruh data (Kapan Deteksi, Kapan Resolusi, Dampak Aset), dan menenunnya menjadi Dokumen PDF Laporan Paska-Insiden (*Post-Incident Report*) rapi yang disusun dalam bahasa bisnis. Laporan ini dikirim secara otonom kepada manajemen melalui email terenkripsi, menutup kewajiban Administratif dan Regulasi (Kepatuhan SLA) secara sempurna.

## 5.5 Audit Trails & Chain of Custody in Automation

Dalam investigasi forensik kriminal yang melibatkan Otoritas Hukum (Polisi Siber / Penegak Hukum), bukti log (Evidence) yang tidak diamankan tidak akan diterima di pengadilan (Inadmissible). Anda tidak bisa mengatakan "Robot SOAR kami secara otomatis menghapus berkasnya".

Otomatisasi Enterprise wajib mempertahankan **Chain of Custody (Rantai Bukti) dan Jejak Audit yang tak terbantahkan (Immutability)**. Setiap tindakan yang diambil SOAR (Waktu tarikan API EDR, *Hash* dari Fail Malware yang disita, dan ID Otentikasi *Approval* perintah Isolasi) di-*Hash* secara Kriptografis (SHA-256) dan disegel sebagai Log Baca-Saja (Read-Only) di *Ledger* Sistem SOAR. Ini memastikan setiap klik Triase Otonom dapat diaudit kembali secara forensik murni tahunan.




# BAGIAN VI

## AI, Machine Learning, & Masa Depan SOAR
## (Rekayasa Presisi Kognitif)

# BAB 6: ANALITIK DATA ADAPTIF (AI)

## 6.1 Machine Learning Classification (Triage Prioritization)

Skoring Risiko Kaku berbasis aturan (Statik If-Then) pada *Playbook* tradisional lama-lama menjadi tidak relevan dalam menghadapi Taktik APT modern. Arsitektur SOC masa depan menyuntikkan (Inject) Algoritma **Machine Learning (Supervised Classification Models)** langsung ke dalam pipa triase peringatan awal.

Model Historis ini dilatih dari ribuan Keputusan Penutupan Insiden Analis Manusia di masa lalu (Ground Truth). Saat sebuah peringatan baru masuk, *Random Forest Classifier* SOAR menghitung probabilitas matematis (misal: `Confidence Score: 98.4% bahwa ini adalah False Positive`) berdasarkan metrik tersembunyi (Features) seperti Varian Beban Karakter (Entropy) pada argumen terminal baris perintah (*Command Line Arguments*). Model ini merutekan klasifikasi cerdas sebelum analis sempat membuka tiketnya.

## 6.2 Integrasi Generative AI (LLM Triage Copilot)

Batas mutakhir SOAR hari ini adalah mengawinkan Pipa Triase Otomatis dengan Model Bahasa Besar (LLM) Awan Pribadi (Private GPT), menghindari pencemaran Data Konfidensial (Data Leakage) ke OpenAI publik.

Ketika *Playbook SOAR* mengekstrak Blok Kode Skrip PowerShell Kriminal (Obfuscated Base64) dari mesin korban, SOAR meneruskan bongkahan kode rumit tersebut ke *LLM Prompt Node*. LLM bertindak sebagai Insinyur Rekayasa Balik (Reverse Engineer) virtual, secara instan men-dekode skrip tersebut, meringkas niat (Intent) dari kode tersebut ("Skrip ini mencoba mematikan Windows Defender dan memanggil Domain C2 `evil.xyz`"), lalu mencantumkan hasil terjemahan kognitif ini langsung ke dalam catatan Kasus Triage Analis manusia (SOC Copilot).

## 6.3 Kueri Dinamis (Auto-Hunting Generation)

Alur triase klasik bersifat Reaktif: Menunggu peringatan (Alert) datang, lalu diselidiki. Integrasi SOAR Lanjut memfasilitasi **Proactive Threat Hunting Automation (Pembuatan Kueri Pemburu Ancaman)**.

Berdasarkan konteks peringatan yang berhasil diverifikasi (Misalnya IP 10.0.0.5 telah dieksploitasi oleh *Log4j*), SOAR secara dinamis menulis *Kueri EQL Splunk/Elastic* (Dynamic String Formatting) dari nol untuk memburu "Apakah IP tersebut sudah berbicara (Lateral Movement) dengan Komputer Peladen Basis Data internal lain di 7 Hari terakhir?". Skrip kemudian menjalankan *Query* baru ini secara mandiri ke SIEM Data Lake (Auto-Retroactive Hunt). Jika ada hasil yang cocok (Hit), ia mengekspansi tiket Kasus secara masif tanpa jeda istirahat (Automated Pivot).

## 6.4 Clustering Alert Similarities (K-Means)

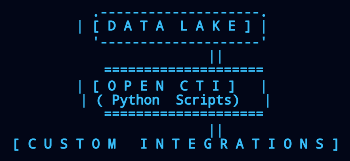
Alih-alih menahan ribuan peringatan dengan aturan pengecualian manual yang kasar (Hardcoded Whitelisting), Insinyur Deteksi Data (Data Scientists) di SOC menerapkan algoritma **Unsupervised Clustering (seperti K-Means atau DBSCAN)** untuk manajemen antrean Peringatan.

Model (AI) ini menelan volume besar Peringatan "Anomali Jaringan" harian yang tak terstruktur dan mengelompokkan (Cluster) mereka ke dalam gelembung-gelembung fenomena matematis yang sangat berdekatan secara multidimensi (Waktu, IP Origin, Rasio Ukuran Byte). Jika satu kelompok raksasa gelembung meledak tak wajar di grafik, Analis tidak melihatnya sebagai 1,000 Peringatan IP, melainkan sebagai "1 Kluster Serangan Terdistribusi (DDoS Triage Cluster)" tunggal yang memampatkan beban analisis dari jam-jaman menjadi pengerjaan satu layar matriks tunggal.

## 6.5 Bias Model & Kepercayaan pada AI (Trust Boundaries)

Menyerahkan respons Kinetik Karantina (Auto-Containment) sepenuhnya kepada Algoritma Hitam (Black-Box AI / Neural Networks) adalah pelanggaran kepatuhan arsitektur Enterprise yang fatal (Catastrophic Risk).

**Model Trust Boundaries (Batas Kepercayaan AI)** menetapkan bahwa mesin Pembelajaran Mesin (AI) HANYA diizinkan untuk memberikan "Saran Rekomendasi Probabilistik" (Probabilistic Advice) kepada lapisan Triase (Enrichment). Keputusan Penahanan (Isolasi Jaringan, Pemutusan Akun API Krusial) HARUS tetap bergantung pada Logika Keputusan Deterministik (Hardcoded Boolean Playbooks) atau, dalam kasus kritis, mensyaratkan Persetujuan Cincin Manusia (Human-in-the-Loop / Manual Approval Gate). Ini menghentikan bencana Pemblokiran Massal (Mass Outage) akibat model AI yang berhalusinasi (Model Drift/Data Poisoning).




# BAGIAN VII

## Arsitektur Data Lake & Ekosistem Terbuka (Menembus Batasan Vendor Proprietary)

# BAB 7: EKOSISTEM KUSTOM SIBER

## 7.1 Ekosistem SOAR Agnostik-Vendor (Vendor-Neutral)

Platform SOAR sering kali (secara historis) dikunci oleh Vendor Keamanan Besar (Vendor Lock-in). Arsitektur Otomatisasi Perusahaan Skala Bebas (Enterprise Agnostic SOAR) dirancang sedemikian rupa agar Playbook-nya terpisah dari antarmuka Produk Vendor Tunggal.

Jika tahun ini Anda menggunakan *Firewall Cisco*, dan tahun depan migrasi ke *Palo Alto*, Anda tidak boleh membangun ulang seluruh 300 *Playbook* isolasi jaringan Anda dari awal. Anda merancang Node *Playbook* Anda secara Agnostik menggunakan (Wrapper API) abstrak seperti `Generic_Isolate_IP()`. Sistem Integrasi (Integration Layer) di bawah SOAR yang akan bertugas menerjemahkan perintah Agnostik abstrak tersebut ke dalam bahasa REST API spesifik (Cisco/PaloAlto). Migrasi *Firewall* Nasional kini dapat diselesaikan hanya dengan mengubah satu kunci integrasi di lapisan *Backend* Otomatisasi.

## 7.2 Integrasi OpenCTI & Pangkalan Data STIX/TAXII

Mengambil Data *Threat Intel* (IP/Hash Berbahaya) mentah dari Vendor sering kali tidak memiliki relasi kontekstual (Taktik, Teknik, Aktor). Arsitek Keamanan menjahit (Stitch) platform SOAR mereka dengan **OpenCTI (Open Cyber Threat Intelligence) Platform** berbasis standar STIX/TAXII.

Saat peringatan SIEM mengenai (Hit) alamat IP `45.x.x.x`, SOAR tidak hanya bertanya kepada API "Apakah ini jahat?". SOAR bertanya kepada OpenCTI. OpenCTI membalas dengan visualisasi Node Graph berantai: IP `45.x.x.x` ==(Digunakan Oleh)==> Grup APT `Lazarus` ==(Dalam Kampanye)==> `Operation Dream Job` ==(Yang Menargetkan)==> Sektor Finansial. Triase Instan ini memberikan Analis L3 Peta Vektor (Vector Map) serangan siber Nasional utuh, mengubah mereka dari "Pembersih Log" menjadi Pemburu Intelijen Negara (State-Intel Analysts).

## 7.3 Menulis Custom Integration Script (Python)

Aplikasi bisnis kustom internal perusahaan (seperti Dasbor Transaksi HRD *In-house*) seringkali tidak memiliki integrasi (Plugin) resmi di *Marketplace SOAR (seperti Cortex/Splunk)*. Insinyur Keamanan memecahkan dinding ini dengan kemampuan *Custom Python Integrations*.

Insinyur mengembangkan skrip *Python* murni menggunakan pustaka `requests` untuk berinteraksi (*REST GET/POST*) dengan gerbang *API Oauth2* Kustom HRD internal. Skrip *Python* yang di-*Upload* (Inject) ke Mesin Docker (Dockerized SOAR Node) ini dapat digunakan langsung oleh Analis L1 sebagai Blok "Tarik Data HRD Pegawai (Fetch Employee Data)" secara visual (Drag-and-Drop) di dalam antarmuka desain *Playbook*, menjembatani alat keamanan global dengan ekosistem aplikasi korporat primitif rahasia lokal Anda (Bridging the Void).

## 7.4 Arsitektur Data Lake & Kueri Tak Terbatas

Menyimpan data log keamanan ke dalam Splunk/SIEM Tradisional selama 1 tahun sering kali membutuhkan biaya Lisensi jutaan dolar yang mencekik (Ingestion Tax). Model Arsitektur Triase Modern menggeser penyimpanan ke **Security Data Lakes (Amazon S3 / Snowflake)**.

Platform SOAR dan Mesin Pencarian Deteksi (seperti *Elastic / Databricks*) di masa depan diarahkan langsung menembak (*Federated Querying*) ke *Bucket S3* mentah berbiaya murah (*Cold Storage/Parquet Format*) tersebut tanpa menariknya (No-Ingest). Pergeseran arsitektur ini membebaskan belenggu Retensi Data (Data Retention Limits), mengizinkan Skrip SOAR Pemburu Ancaman (Threat Hunting Automations) Anda untuk menelusuri ke belakang (Retroactive Sweep) mencari IOC kerentanan *Zero-Day* hingga 5 Tahun lamanya ke dalam memori masa lalu perusahaan dengan kecepatan komputasi Awan (Cloud Compute Speed) yang mencengangkan.

## 7.5 Kesimpulan Arsitektur Orkestrasi

Automasi SOC bukan tentang menggeser tugas manusia ke mesin (Replace Humans); ini adalah Orkestrasi Kognitif untuk **Pemberdayaan Super (Human Augmentation)**. *Security Orchestration, Automation, and Response (SOAR)* mengangkat Analis Keamanan Anda dari rawa keputusasaan operasional berulang (*Alert Fatigue*) dan meletakkan mereka ke kursi Kapten Pengendali Pusat Komando (Command Center).

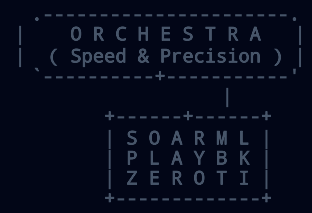
Dengan menerapkan fondasi Triase Pengayaan (Enrichment) absolut, Playbook Karantina Defensif yang Aman dari Keruntuhan (Fail-safe Containment), dan Pengecualian (*Exceptions Management*) berlapis baja; Tim Pusat Operasi Keamanan Anda tidak lagi merespons insiden Siber—Tim Anda secara harfiah Mendikte (*Dictating*) tempo dan ritme pertempuran siber di Perimeter Infrastruktur Anda.

# REFERENSI JURNAL & STANDAR (NIST/SANS)


- **[1]** NIST. (2012). *SP 800-61 Rev. 2: Computer Security Incident Handling Guide*. (Cetak biru referensi siklus penahanan, pemberantasan, dan pemulihan insiden).
- **[2]** SANS Institute. (2020). *Security Orchestration, Automation, and Response (SOAR) Architecture Metrics*. (Studi teknis metrik penekanan kebisingan MTTA dan MTTD di SOC).
- **[3]** MITRE Corporation. (2025). *MITRE ATT&CK® Framework integration for SIEM and Automation Mapping*. (Penelaahan taksonomi musuh tingkat lanjut untuk kategorisasi *Playbook* otonom).
- **[4]** LuigA, F. & Filigran. (2024). *Open Cyber Threat Intelligence Platform (OpenCTI) Documentation*. (Integrasi arsitektural grafik relasi STIX 2.1 ke Otomasi SIEM/SOAR).

# GLOSARIUM TERMINOLOGI SOAR

| TERMINOLOGI | DEFINISI & KONTEKS OTOMASI SIBER |
|---|---|
| **Alert Fatigue (Kelelahan Peringatan)** | Fenomena pengikisan psikologis Analis L1/L2 akibat paparan volume peringatan palsu (False Positives) tak terhingga dari SIEM yang tak disetel, menyebabkan Klik-Buta dan membiarkan serangan nyata (True Positives) lolos tanpa analisis mendalam. |
| **Enrichment (Pengayaan Triase)** | Fase Automasi Aman pertama. Pipa logis *Playbook* menarik Indikator EntitasMentah dari *Alert* (IP, Hash, UserID), menanyakan API *Threat Intel* eksternal secara otomatis, lalu menggabungkannya sebagai Konteks Laporan Matang di satu layar bagi Analis. |
| **Playbook (Buku Panduan Otonom)** | Grafik Alur Kerja visual atau Skrip Python terstruktur (Conditional If-Then) dalam platform SOAR yang mendikte urutan langkah eksekusi (Tarik Data -> Analisis -> Persetujuan -> Karantina Endpoint) secara logis tanpa intervensi jeda. |
| **SOAR (Security Orchestration, Automation and Response)** | Platform mesin perangkat lunak terpusat yang menjadi "Jaringan Saraf Penggerak" SOC. Menyerap alarm dari SIEM, merutekannya via *Playbooks*, dan memerintahkan produk infrastruktur keamanan siber eksternal (EDR/Firewall) via integrasi (REST API) lintas vendor. |




# The Automation Architect

© 2026 All rights reserved.
Enterprise Cyber-Operations Series